SOP - SECURITY REQUIREMENT

[CONFIDENTIAL]
[UTTHUNGA]
[IndiQube, South Summit, South End Rd, Vijayarangam Layout, Bengaluru, Karnataka 560004]

Contents

1 Purpose 3
2 Scope 3
3 Abbreviations 3
4 Terms and Definitions 3
5 Responsibilities 3
6 Overall Process Flow Chart 6
7 Process Description 7
8 Information Security requirements 12
9 References 12
10 Metrics 12
11 Annexures 12
12 Forms 12

CHANGE HISTORY

This section describes the details of changes that have resulted in the current document.

SL. No.	Document Version No.	Change Description	Reason For change	Date Prepared By	Date Reviewed By	Date Approved By
01	0.1	Draft		Anitha N 04-05-24		
02	Issue B, V1.0	New process Implementation			Santosh V 10-05-24	Santosh V 10-05-24
03	Issue B V1.1	1. Updated Section 14 2. Document formatting done as per document guidelines	Provided relevant links for forms related to SOP	Vanavee P 09-Dec-24	Anitha N 09-12-24	Santosh V 10-12-24
04	Issue C Version 1.0	Review of document	New version update of IMS	Anitha N 01-Aug-25	Santosh V 08-Aug-25	Sanmangala MS 14-Aug-25

1 Purpose

To establish a systematic approach for defining, documenting, and maintaining security requirements throughout the product development lifecycle.

2 Scope

This SOP covers engaging stakeholders, documenting product security context, performing continuous threat modeling, defining security requirements, and reviewing threat models and security requirements.

3 Abbreviations

a. SOP: Standard Operating Procedure

b. IEC: International Electrotechnical Commission

c. UML: Unified Modeling Language

4 Terms and Definitions

a. Security Requirements: Detailed specifications and controls to ensure the security of a product or system.

b. Threat Modeling: Systematic process to identify potential security threats and vulnerabilities.

c. Trust Boundaries: Boundaries within a system where security assumptions change, or authentication is required.

d. Attacker Model: Description of the malicious intents and capabilities of a potential attacker.

e. Mitigations: Actions or measures to reduce the risk of identified threats.

f. Risk Tolerance Policy: A predefined level of risk that an organization is willing to accept.

g. SUC (System Under Consideration): The specific system being analyzed for security requirements.

5 Responsibilities

a. Project Manager: Ensure compliance with SR-1 of IEC 62443-4-1 and manage the security context.

b. Security Experts/Architects: Engage in defining security requirements, conduct threat modeling, and review security documentation.

c. Developers: Integrate security requirements into the development lifecycle and traceability between requirements and design/implementation/testing.

d. Security Manager: Approve security requirements documentation and provide feedback during the review process.

e. Product Management: Provide feedback and approval for security requirements documentation.

f. Stakeholders: Engage in providing input on security requirements and participate in reviews.

g. Testers: Independently review threat models and ensure the comprehensiveness and relevance of security requirements.

6 RACI

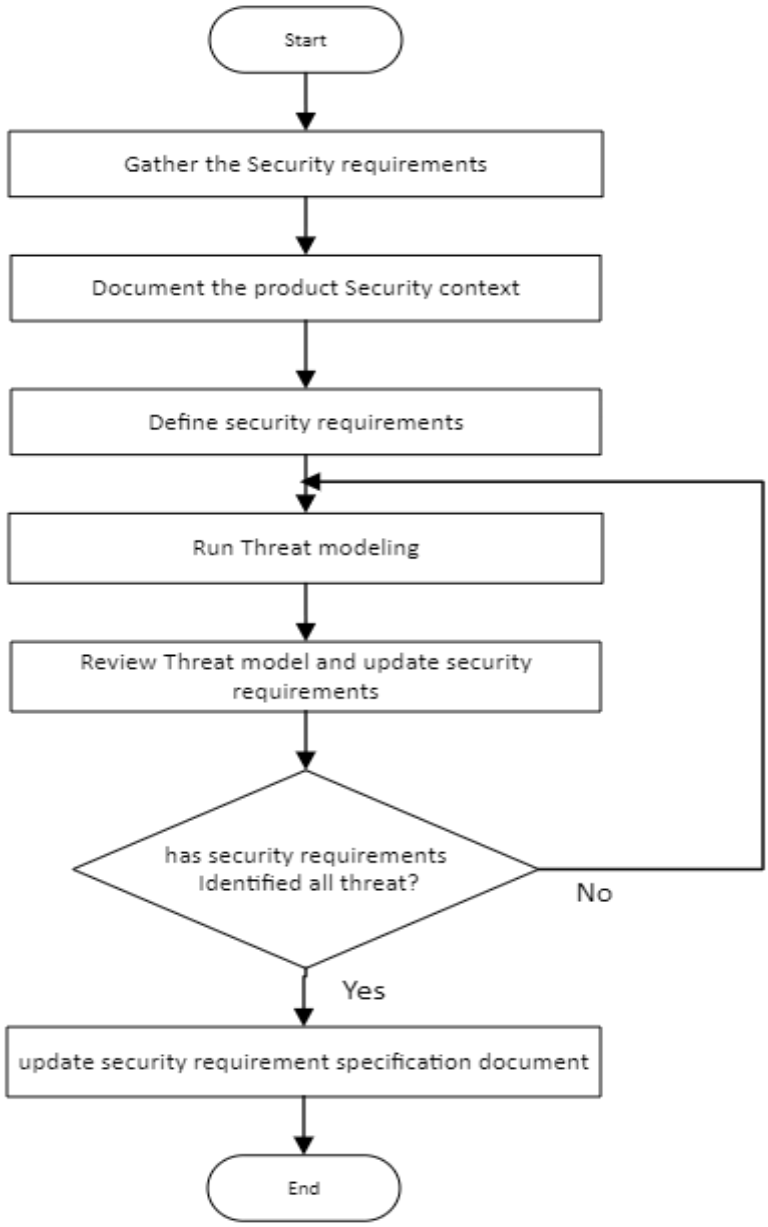
Process	Responsible	Accountable	Consulted	Informed
Security Requirements	Security Analysts, Project Managers, Security Engineers	Security Manager	Developers, Stakeholders, Customers	Development Team, Product Management
Document Product Security Context	Project Managers	Security Manager	Security Analysts	Development Team, Stakeholders, Product Management
Performing continuous threat modeling	Security Analysts, System Architects	Security Manager	Developers, Testers	Development Team, Product Management
Defining security requirements	Security Analysts, System Architects, Project Managers	Security Manager	Developers, Stakeholders	Development Team, Product Management
Reviewing Threat Model and security requirements	Security Analysts, Project Managers	Security Manager	Developers, Testers, Product Owners	Development Team, Product Management

7 SIPOC

Supplier	Input	Process and Control		Output	Customer
		Process	Control		
Relevant Stakeholders, Regulatory Bodies	Stakeholder input, Regulatory requirements	Security Requirements	Security reviews, Compliance checks	Comprehensive security requirements documentation	Development Team, Stakeholders
Project Managers	Project requirements, Security standards	Document Product Security Context	Compliance checks	Documented product security context	Development Team, Stakeholders, Product Management
Security Analysts, System Architects	System architecture diagrams, External dependencies	Performing continuous threat modeling	Risk assessments, Compliance checks	Updated threat models, Risk assessments	Development Team, Product Management
Security Analysts, System Architects	Threat models, Security mitigations	Defining security requirements	Compliance checks, Risk assessments	Documented security requirements	Development Team, Product Management
Security Analysts, Project Managers	Updated threat models, Security requirements	Reviewing Threat Model and security requirements	Review processes, Compliance checks	Revised threat models, Updated security requirements	Development Team, Product Management

8 Overall Process Flow Chart

a) Security requirements



9 Process Description

9.1 General Procedure

a. Engage relevant stakeholders to gather input on security requirements. This shall include regulatory requirements, industry standards, customer expectations, and internal security policies.

b. Define the security requirements for the product based on the gathered input. This includes identifying functional security requirements, specifying security controls, determining security architecture principles, creating threat models, and conducting risk assessments.

c. Document the security requirements in a comprehensive document that covers all aspects outlined in SDLA-SR-4. This document should be detailed, clear, and structured to facilitate understanding and implementation by the development team.

d. Conduct a thorough review of the security requirements documentation to ensure completeness, accuracy, and alignment with security objectives. This review should involve security experts, architects, developers, and other relevant stakeholders.

e. Revise the documentation based on feedback received during the review process. Address any identified gaps, inconsistencies, or ambiguities. Obtain approval from key stakeholders, including security manager and product management.

f. Integrate the approved security requirements documentation into the product development process. Ensure that the security requirements are considered throughout the development lifecycle, including design, implementation, testing, and maintenance phases.

g. Traceability shall be established between the requirements to design, requirements to implementation and requirements to testing and defects management.

h. Continuously monitor and update the security requirements documentation as needed throughout the product lifecycle. This includes incorporating changes in security threats, vulnerabilities, regulations, and customer feedback.

i. Track the security issues which arise from requirement phase and bring it to closure. refer security issues management SOP for further details.

j. Maintain the security requirements documentation in a centralized repository and ensure that it is kept up to date with any changes or revisions. This documentation should be readily accessible to all relevant stakeholders.

Note: For a detailed requirement process, refer Utthunga' s Requirement SOP

9.2 Document Product Security Context

a. As per SDLA-SR-1 of IEC 62443-4-1 requirements, Project Manager or a person designated by PM shall ensure that the developed product considers its intended use and operating environment. document the minimum-security requirements of the operating environment and the relevant security assumptions, which we refer to as the security context. The security context shall include the following information:

b. The envisioned deployment location of the product

c. The on-site security measures provided by the operating environment.

d. The network isolation settings, such as those provided by firewalls and virtual subnets.

e. How a security incident could impact the operating environment (for example, loss of life. injury, loss of production, etc.)

f. Requirement specification template should be used which is available in IMS

9.3 Performing Continuous Threat Modeling

As per SDLA-SR-2 of IEC 62443-4-1,

a. To determine suitable security requirements, regularly perform threat modeling to systematically identify security threats.

b. Create a threat model (using the Threat Modeling Template) that consists of the following information:

c. System Model:

- Provide an overview of all components (processes, data stores) in the product and its external dependencies. You can use existing software architecture diagrams to avoid duplicated work.

Include the following information:

- External entities that interact with the product
- Physical ports that are externally accessible, such as debug ports. RS-232 ports. USB ports
- Connectors on the circuit board such as JTAG, SWD, or other debug ports

- Describe the data flow between the components and with external systems. You can also use other methods like UML sequence diagrams to avoid duplicated work.
- Define the trust boundaries in the architecture, which are boundaries between components where authentication is required or the security assumptions change. Use these boundaries to define zones and conduits when performing risk assessment during system design.
- Clearly highlight in the diagram or define the system under consideration (SUC).

d. Attacker Model:

- Describe reasonable malicious intents and capabilities of an attacker.
- Threats and attack vectors:
  - Provide a list of security threats that the attacker (defined in the attacker model) can have on the product (defined in the system model and operating environment). To ensure that the list is comprehensive, you can follow some established methods like STRIDE.
  - Assign each threat a risk level or severity level, such as using IEC 62443-3-2 annex B. Risk matrices.
  - Consider attacks on both the software and hardware, wherever applicable.
- Mitigations: For each threat or attack vector, describe the mitigations and/or disposition. In other words, document the security mechanisms that we reduce the risk of the threat or a decision and/or explanation to accept the associated risk.
- Additional security-related issues: Document any other security issue that does not fit into the categories above.
- External software dependencies: List and track all the externally developed software components. This can be replaced by automated solutions such as Software Composition Analysis in Security Verification and Validation Testing.
- Risk Tolerance Policy (Security Bug Bar):
  - Determine and commit to a minimum accepted severity level or threshold risk level, which is based on the business risk of the

product. E.g. define your own bug bar (example) and agree to handle all vulnerabilities above medium severity level.

- In the early stages of product development, you can start by only providing the high-level components (e.g. mobile app. edge, cloud, database). As the team takes decisions regarding detailed components (e.g. communication interfaces on an embedded device. subnets in a cloud environment), you can continuously edit the threat model.

9.4 Defining Security Requirements

a. SR-3 SR-4

Based on the threat model and the mitigations of the identified threats, document the scope and boundaries of the product where suitable security requirements should be satisfied.

Determine the suitable security requirements for the product using the following information:

- The threats identified in the threat model whose severity level exceeds the minimum acceptable risk level
- The determined required capability security level of the product, as defined in IEC 62443-4-2
- The entire lifecycle of the product, including security requirements for the following stages:
  - Installation, e.g. secure creation of user accounts
  - The operation. e.g. user account management
  - Maintenance, e.g. secure software update and code signing
  - Decommissioning. e.g. removal of sensitive information before disposal

9.5 Reviewing Threat Model and Security Requirements

a. SR-5

To consider the latest trends in the threat landscape and ensure that our products are sufficiently protected against them, we should continuously maintain the threat model and review the security requirements by adopting the following best practices:

- Update the threat model periodically (at least once a year) and whenever the design changes in a significant way, such as adding a new product feature or adding a new interface.
- Review the threat model within the development team to ensure its comprehensiveness and relevance. Include the following profiles in the review:
    - At least one security advisor or expert
    - Product owners or customer advocates
    - Product developers, operators, and architects
    - Testers, who must be independent of other roles mentioned in this list
- Review the security requirements and ensure that they match the threats identified in the threat model.
- Collaboratively maintain the threat model and the security requirements
- During the reviews, the participants can also propose to improve the process as needed by following the actions mentioned in Security Management | Establish Continuous Improvement.
- Review the security requirements and ensure that they match the threats identified in the threat model.
- Collaboratively maintain the threat model and the security requirements
- During the reviews, the participants can also propose to improve the process as needed by following the actions mentioned in Security Management | Establish Continuous Improvement.

10 Information Security requirements

All information related to security requirements, threat models, and security context must be stored in a secure, centralized repository with restricted access to authorized personnel only. All data must be encrypted during transit and at rest.

11 References

a. Microsoft Word - 2. Threat Modeling Guidelines UTSDDSPGDL02

b. SOP-Requirements Specification (RSP)-UTSDRSPSOP.pdf

12 Metrics

a. Number of security requirements defined and implemented.

b. Number of threat models created and updated.

c. Number of security issues identified and resolved.

d. Frequency of security requirement and threat model reviews.

13 Annexures

a. None

14 Forms

a. 6.Mobile App Security Checklist-1.2 UTSDRSPTMP06.xlsx

b. 1.Requirement Specification Template UTSDRSPTMP01.docx

c. 08. Cyber Security Threat Model Template UTSDDSPTMP08.xlsx

d. 5. SDL Questionnaire Security Requirement UTSMOMPTMP05